>_ CYBER TECH ACADEMY

Threat Hunting & CTF Practice

Develop hypotheses, investigate telemetry, solve safe capture-the-flag tasks, and communicate evidence-based findings.

LEVEL: ADVANCED

Creator: Dhanush | **Edition:** 1.0 | **Cost:** Free

How to use this guide

Read the concepts first, run examples only in a system you own or are authorised to use, complete the lab, then answer the review questions without looking back. Commands and outputs can differ by Linux distribution, software version, and local configuration.

Responsible learning: only test systems for which you have explicit permission. These notes are educational and do not grant permission to access, scan, disrupt, or modify third-party systems.

Learning objectives

- Create testable threat-hunting hypotheses.
- Use indicators of compromise carefully and in context.
- Investigate synthetic endpoint, authentication, and network data.
- Solve beginner-to-advanced CTF reasoning tasks responsibly.
- Explain findings, confidence, false positives, and recommended actions.

Contents

- 1. What threat hunting is
- 2. Indicators and behaviour
- 3. A repeatable hunting workflow
- 4. Capture-the-flag (CTF) skills
- 5. Cryptography, forensics, and web reasoning
- 6. Turning findings into better defences
- Guided practical lab
- Knowledge check
- Glossary

1. What threat hunting is

Threat hunting is a structured search for activity that may have escaped existing alerts. It differs from routine alert triage because the analyst begins with a hypothesis or question and actively seeks supporting or contradictory evidence.

A useful hypothesis is specific and testable. Example: 'A privileged account may have been used from an unusual device after repeated authentication failures.' Define the data sources, time window, expected normal behaviour, suspicious pattern, and evidence that would weaken the hypothesis.

Hunting is iterative. A lead can be benign, suspicious, or inconclusive. Record the query, filters, time range, data gaps, and reasoning so another analyst can reproduce the result.

2. Indicators and behaviour

Indicators of compromise (IOCs) include hashes, domains, IP addresses, filenames, and other artefacts associated with suspicious activity. IOCs have context and lifetimes: infrastructure can be shared, recycled, or legitimate, and a hash may identify only one version of a file.

Behaviour-based clues can include unusual process ancestry, unexpected remote administration, suspicious authentication sequences, rare outbound connections, new persistence, or a sudden change in data access. No single behaviour automatically proves malicious intent.

Prefer multiple independent signals. Consider asset role, user schedule, approved changes, software inventory, known maintenance, and telemetry quality. State confidence and alternative explanations.

3. A repeatable hunting workflow

1. Define a question and scope. 2. Identify available telemetry. 3. Write a hypothesis. 4. Build a query or filter. 5. Examine results. 6. Pivot to related events. 7. Validate context. 8. Record findings and gaps. 9. Recommend a detection or control improvement.

Queries should be narrow enough to explain and broad enough not to hide relevant evidence. Avoid searching only for a single known indicator; attackers and tools change. Baseline normal activity and review exceptions.

Successful hunts can produce new detections, improved logging, asset fixes, or a documented conclusion that the available evidence does not support the hypothesis.

4. Capture-the-flag (CTF) skills

A CTF is a controlled challenge in which a participant solves a puzzle or security task to find a flag, often a text string. Categories may include Linux, networking, cryptography, web security, forensics, and reverse engineering. Always follow the event rules and stay inside the supplied environment.

Begin by reading the challenge description and identifying what is provided. Inspect file types, metadata, strings, hashes, and logs before choosing tools. Make a copy of supplied artefacts and keep notes about each step.

Flags are proof of completing a task, not permission to attack the challenge host or related infrastructure. Do not reuse techniques against real systems unless separately authorised.

5. Cryptography, forensics, and web reasoning

CTF tasks sometimes confuse encoding with encryption. Base64 is an encoding scheme, not encryption; it does not provide secrecy. Hashes are one-way digests, and encrypted data requires the appropriate key and algorithm to recover plaintext.

Forensics challenges may ask you to identify a file type, reconstruct an event timeline, compare hashes, or interpret a packet capture. Keep evidence provenance and avoid treating metadata alone as conclusive.

Web challenges should be performed in a deliberately vulnerable local or hosted training environment. Focus on root cause and remediation: output encoding for XSS, parameterised queries for SQL injection, and server-side access control for authorisation flaws.

6. Turning findings into better defences

A hunt should end with a useful outcome: confirmed incident escalation, a benign explanation, a telemetry gap, a new detection, or a recommendation. Record the affected assets, evidence, confidence, business impact, and next steps.

Detection logic needs testing. Evaluate whether it catches the intended pattern, how often it triggers on normal activity, what data it requires, and how an analyst will investigate it. Tune carefully so that reducing noise does not hide real threats.

CTF write-ups should explain the reasoning and learning objectives without exposing real secrets or encouraging out-of-scope activity. Include assumptions, commands or queries used, results, and defensive lessons.

Guided practical lab

Synthetic hunt: analyse this fictional sequence and propose next steps.

```
08:40Z host=WS-04 event=login_failed user=admin src=198.51.100.24
08:41Z host=WS-04 event=login_failed user=admin src=198.51.100.24
08:42Z host=WS-04 event=login_success user=admin src=198.51.100.24
08:45Z host=WS-04 event=process_started name=archive_tool parent=browser.exe
08:47Z host=WS-04 event=outbound_connection dest=203.0.113.70 port=443
08:48Z host=WS-04 event=file_access name=finance-demo.csv
```

- Write a hypothesis that can be tested with available telemetry.
- List at least three additional data sources to check.
- Identify benign explanations and evidence that would support or weaken each.
- Decide what would justify escalating to incident response.
- Propose one detection improvement and one preventive control.

All addresses, hosts, users, and events in this scenario are synthetic documentation examples. The sequence is suspicious enough to investigate, but it does not prove compromise by itself.

Knowledge check

Try to answer these before checking the answer key. Write your reasoning, not just a single word.

1. How does threat hunting differ from routine alert triage?

Answer: _____

2. Why can an IOC produce false positives?

Answer: _____

3. Is Base64 encryption?

Answer: _____

4. What should a hunt document even when it finds nothing?

Answer: _____

5. What makes a good CTF write-up?

Answer: _____

Answer key and reasoning

1. Hunting proactively tests a hypothesis or question across telemetry, while triage evaluates a specific alert or reported event.

2. An indicator can be shared, recycled, misattributed, or associated with legitimate activity; context and corroboration matter.

3. No. Base64 is an encoding scheme and provides no secrecy.

4. The hypothesis, scope, queries, time range, data sources, limitations, and why the evidence did not support the hypothesis.

5. Clear reasoning, reproducible steps within the authorised environment, the result, assumptions, and defensive lessons.

Glossary

Term	Meaning
Threat hunting	Proactive, hypothesis-driven investigation of telemetry.
IOC	Indicator associated with potentially malicious activity.
Telemetry	Recorded information about system or network behaviour.
Hypothesis	A specific, testable explanation or question.
CTF	Capture-the-flag learning challenge in a controlled environment.
False positive	Benign activity incorrectly classified as suspicious.

Further study

Continue with the next Cyber Tech Academy module, practise in a disposable virtual machine or an explicitly authorised lab, and consult official manuals for the tools you use. Verify commands against your own system before running them.

Cyber Tech Academy • Free learning • Learn the theory. Practise safely. Build real skills.